

Introdução

Vivemos um cenário em que as ameaças digitais ganham contornos cada vez mais complexos e as exigências regulatórias, como a LGPD, impõem um ritmo de adaptação constante. Para os órgãos públicos, o desafio vai além de apenas cumprir regras; trata-se de construir uma estrutura de segurança da informação que seja robusta, resiliente e, acima de tudo, integrada ao dia a dia da instituição. É nesse contexto que o Programa de Privacidade e Segurança da Informação (PPSI) se apresenta não apenas como uma diretriz normativa, mas como o alicerce estratégico para a sobrevivência e a confiabilidade do serviço público.

Este curso, "Elaborando Políticas de Segurança para o PPSI", foi desenhado para ser o seu guia prático nessa jornada de transformação. Ao longo de dez módulos, vamos percorrer todo o ciclo de vida da segurança da informação, desde a governança inicial até a implementação técnica de controles, gestão de riscos, resposta a incidentes e conformidade legal. Nosso objetivo não é oferecer um conteúdo teórico distante da realidade, mas sim capacitar você e sua equipe a escrever, implementar e auditar políticas que realmente funcionem — saindo da burocracia para entregar uma segurança que sustenta a operação, mesmo diante de crises.

Ao final deste curso, o nosso objetivo é que você esteja preparado para alinhar as práticas da sua organização à Portaria SGD/MGI n.º 9.511/2025, reduzindo vulnerabilidades e elevando a maturidade cibernética da instituição. Mais do que atender auditorias, a nossa proposta é ajudar você a disseminar uma cultura de segurança que faça sentido para todos os servidores, transformando diretrizes complexas em ferramentas vivas, práticas e totalmente conectadas às prioridades estratégicas do seu órgão.





Objetivos de Aprendizagem

Ao longo do módulo, você aprofundará seus conhecimentos sobre os conteúdos específicos abordados e, ao final, deverá alcançar os seguintes objetivos de aprendizagem:

1

Alinhamento Normativo: Capacitar o aluno a alinhar as práticas da sua organização às diretrizes da **Portaria SGD/MGI nº 9.511/2025**, que institui o PPSI 2.0.

2

Desenvolvimento de Políticas: Habilitar o participante e sua equipe a **escrever, implementar e auditar políticas de segurança** que sejam funcionais e sustentem a operação institucional, mesmo em situações de crise.

3

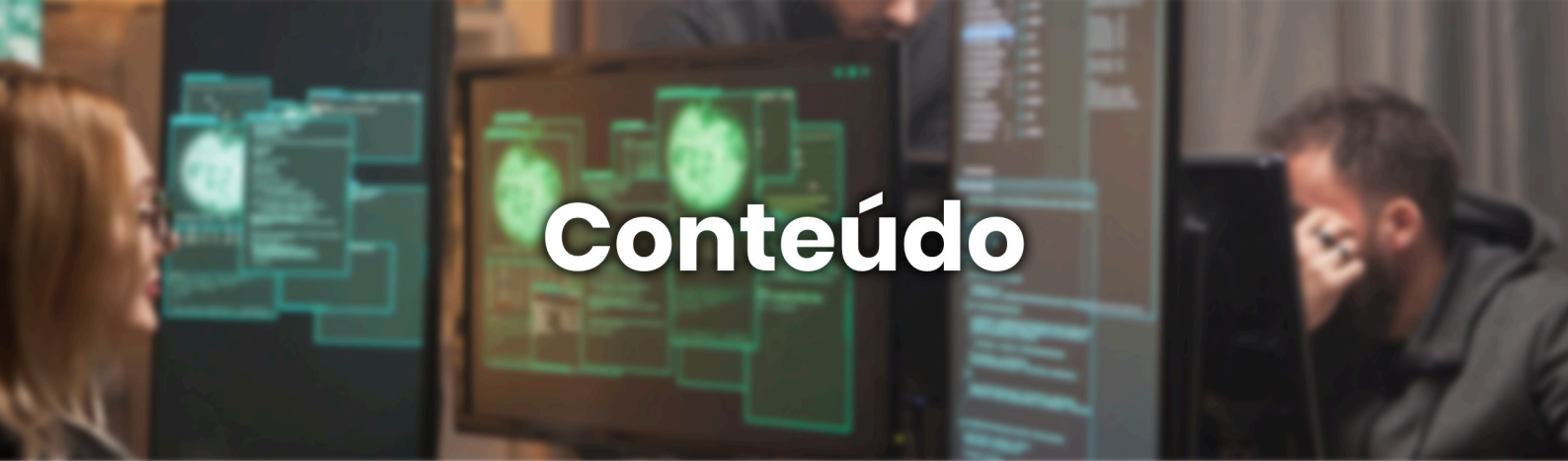
Gestão de Maturidade e Riscos: Preparar o aluno para **reduzir vulnerabilidades e elevar a maturidade e resiliência cibernética** da instituição, utilizando metodologias como o CIS RAM para diagnósticos técnicos.

4

Aplicação de Frameworks Internacionais: Prover uma compreensão sólida de como integrar padrões globais (como **ISO 27001, NIST CSF 2.0 e CIS Controls**) à realidade da administração pública brasileira.

5

Cultura e Engajamento: Disseminar uma **cultura de segurança da informação** que faça sentido para todos os servidores, transformando diretrizes complexas em ferramentas práticas conectadas às prioridades estratégicas do órgão.



Conteúdo

Introdução ao PPSI e à Gestão de Segurança da Informação

O que é o PPSI e sua importância para a administração pública

No dia a dia do setor público, a segurança da informação é frequentemente vista como um conjunto de travas técnicas ou obrigações burocráticas. O Programa de Privacidade e Segurança da Informação (PPSI), instituído pela Portaria SGD/MGI nº 9.511/2025 (em vigor a partir de 01/01/2026), nasce para mudar essa lógica.

Pense no PPSI não como uma "lista de regras", mas como o alicerce estratégico do seu órgão. Ele é o mapa que organiza como protegemos os dados — sejam do cidadão ou da própria instituição — durante todo o seu ciclo de vida. O grande diferencial do programa é harmonizar a necessidade de seguir leis complexas (como a LGPD) com boas práticas internacionais (como ISO 27001, NIST e CISControls), transformando o dever constitucional de proteger dados em um sistema de trabalho eficiente.

Por que o PPSI é indispensável hoje?

O PPSI é indispensável hoje porque profissionaliza a gestão de risco no Estado. Ele unifica governança, controle técnico e cultura organizacional, permitindo que a Administração Pública evolua de uma postura reativa para uma atuação estratégica. O resultado prático dessa implementação é a garantia de que as informações críticas permaneçam confidenciais, íntegras e disponíveis, consolidando a confiança do cidadão nos serviços estatais.

Estrutura Organizacional e Objetivos do PPSI

Conforme o disposto na Portaria SGD/MGI nº 9.511/2025, o PPSI 2.0 tem como objetivo elevar a maturidade e a resiliência dos órgãos e entidades em termos de privacidade e

segurança da informação no âmbito do SISP.

Para não criar burocracia excessiva, o PPSI organiza cinco papéis estratégicos que devem atuar em sintonia, evitando que a segurança fique isolada em "silos":

Alta Administração:

Provê direcionamento estratégico, decisões críticas e liberação de recursos necessários para o programa.

Gestor de TI:

Desenha e executa controles de segurança específicos no ambiente tecnológico e na cadeia de suprimentos.

Gestor de Segurança da Informação:

Realiza diagnósticos técnicos profundos e modela as salvaguardas de proteção.

Encarregado (DPO):

Guardião das garantias de privacidade, assegurando o cumprimento das regras de proteção de dados pessoais.

Responsável pela Integridade:

Atua na articulação integrada, evitando que os processos institucionais funcionem de forma isolada.

Regulamentado pelo art. 4º da Portaria, o programa opera através de cinco eixos temáticos

1

Governança: Garante a coordenação estratégica, o alinhamento a políticas públicas e a otimização de recursos institucionais.

2

Maturidade: Foca na avaliação contínua e no aprimoramento dos controles de privacidade e segurança do órgão.

3

Metodologia: Padroniza a gestão de riscos e processos de adequação, utilizando referências como ISO 27005 ou CIS RAM.

4

Pessoas: Promove a cultura de segurança através de planos de conscientização, treinamentos e engajamento dos servidores.

5

Tecnologia: Define a implementação técnica de controles, ferramentas de proteção e segurança na cadeia de suprimentos de TI.

Para dar suporte a essa estrutura, o programa conta com dois centros nacionais de excelência: o **CISC gov.br**, que atua na linha de frente da prevenção e resposta a incidentes, e o **CEPS gov.br**, focado em promover a cultura de privacidade e segurança por meio de capacitação e boas práticas, além claro da **REGIC** (Rede de Federal de Gestão de Incidentes Cibernéticos). Qualquer plano de conscientização institucional deve buscar articulação com

essas iniciativas nacionais, ganhando escala e legitimidade.

O Ciclo de Execução: PPSI na prática

O PPSI não é estático; ele funciona em um ciclo contínuo composto por diagnóstico, análise de lacunas, planejamento e implementação. Nesse fluxo, o órgão avalia sua situação atual, identifica o que falta, planeja ações e implementa melhorias. Esse processo gera resultados que precisam ser documentados e reportados à Secretaria de Governo Digital (SGD). Em suma, o PPSI converte normas complexas em um método de trabalho vivo, onde o objetivo final não é apenas o "selo de conformidade", mas a resiliência e a maturidade cibernética que o órgão precisa para enfrentar ameaças reais.

Conceitos Fundamentais de Segurança da Informação: A Tríade CIDA

A base para a proteção de sistemas e dados contra ameaças digitais fundamenta-se em três pilares essenciais de segurança da informação, amplamente conhecidos pela sigla CIDA: Confidencialidade, Integridade, Disponibilidade e Autenticidade.

A **confidencialidade** garante que as informações sejam acessadas apenas por pessoas autorizadas, protegendo dados sensíveis contra acessos indevidos, espionagem ou vazamentos — na prática, isso se traduz em criptografia, controle de acesso por senha e autenticação multifator.

A **integridade** assegura que a informação não seja alterada de forma indevida, seja por erro ou por ação maliciosa, mantendo a exatidão e a confiabilidade dos dados ao longo do tempo por meio de assinaturas digitais, somas de verificação e controle de versões.

A **disponibilidade**, por sua vez, garante que a informação e os sistemas estejam acessíveis sempre que necessário, evitando interrupções nos serviços por meio de *backups*, redundância de servidores e planos de continuidade de negócios.

E a **autenticidade** confirma a identidade de usuários ou sistemas que acessam ou transmitem informações, prevenindo fraudes e garantindo que a comunicação seja confiável. Métodos comuns incluem autenticação multifator, certificados digitais e protocolos de verificação de identidade.

Esses quatro pilares operam de maneira interdependente, de modo que a fragilidade de um deles compromete a eficácia de todo o ecossistema de proteção. Portanto, o desenvolvimento de uma política de segurança eficiente exige um equilíbrio contínuo entre esses conceitos, ajustando-se às prioridades estratégicas e aos riscos específicos de cada organização.

Visão Geral das Normas e Frameworks de Referência (ISO 27001, CIS, NIST, LGPD, GDPR)

Com o objetivo de proporcionar uma compreensão mais nítida sobre o suporte dessas diretrizes, apresentamos a seguir uma síntese dos conceitos fundamentais que estruturam sua base técnica.

Norma ISO/IEC 27001

Como padrão internacional consagrado, a ISO/IEC 27001 estabelece os requisitos indispensáveis para a concepção, implementação, manutenção e aprimoramento contínuo de um Sistema de Gestão de Segurança da Informação (SGSI). A finalidade central dessa norma é salvaguardar os ativos de informação por meio de uma estrutura consolidada de políticas, processos e controles, assegurando de forma constante a confidencialidade, a integridade e a disponibilidade dos dados organizacionais.

Fundamentada no ciclo dinâmico do PDCA (*Plan-Do-Check-Act*), a norma consolida um modelo de governança que unifica e integra processos, pessoas e recursos tecnológicos — pilares que também sustentam o Programa de Privacidade e Segurança da Informação sob a Portaria SGD/MGI n.º 9.511/2025. No contexto da administração pública, ela atua como um guia metodológico essencial para a identificação e tratamento de riscos, estruturação de salvaguardas técnicas, definição de responsabilidades e acompanhamento da melhoria contínua, organizando-se em diretrizes como liderança, planejamento, apoio, operação, avaliação de desempenho e ações corretivas.

CIS - Center for Internet Security

O CIS Controls v8.1 consiste em uma estrutura prioritária de 18 controles de segurança pragmáticos, formulados a partir do mapeamento de ameaças reais e incidentes históricos. É amplamente adotado em escala global como um roteiro prático e focado para a mitigação mensurável de riscos de segurança digital.

Em complemento, o CIS RAM (*Center for Internet Security Risk Assessment Method*), desenvolvido em parceria com a HALOCK Security Labs, constitui uma metodologia de avaliação de riscos ágil e estruturada. Seu propósito é viabilizar que as instituições apliquem os Controles CIS de acordo com suas realidades de negócio e necessidades específicas de segurança.

Graças a essa flexibilidade de aplicação, a modelagem se ajusta a organizações de variados portes e setores, propiciando que as medidas defensivas correspondam precisamente aos limites de risco tolerados por cada entidade.

O método CIS RAM orienta as organizações na busca por respostas a questões como:

Visão Geral das Normas e Frameworks de Referência (ISO 27001, CIS, NIST, LGPD, GDPR)

Com o objetivo de proporcionar uma compreensão mais nítida sobre o suporte dessas diretrizes, apresentamos a seguir uma síntese dos conceitos fundamentais que estruturam sua base técnica.

Norma ISO/IEC 27001

Como padrão internacional consagrado, a ISO/IEC 27001 estabelece os requisitos indispensáveis para a concepção, implementação, manutenção e aprimoramento contínuo de um Sistema de Gestão de Segurança da Informação (SGSI). A finalidade central dessa norma é salvaguardar os ativos de informação por meio de uma estrutura consolidada de políticas, processos e controles, assegurando de forma constante a confidencialidade, a integridade e a disponibilidade dos dados organizacionais.

Fundamentada no ciclo dinâmico do PDCA (*Plan-Do-Check-Act*), a norma consolida um modelo de governança que unifica e integra processos, pessoas e recursos tecnológicos — pilares que também sustentam o Programa de Privacidade e Segurança da Informação sob a Portaria SGD/MGI n.º 9.511/2025. No contexto da administração pública, ela atua como um guia metodológico essencial para a identificação e tratamento de riscos, estruturação de salvaguardas técnicas, definição de responsabilidades e acompanhamento da melhoria contínua, organizando-se em diretrizes como liderança, planejamento, apoio, operação, avaliação de desempenho e ações corretivas.

CIS - Center for Internet Security

O CIS Controls v8.1 consiste em uma estrutura prioritária de 18 controles de segurança pragmáticos, formulados a partir do mapeamento de ameaças reais e incidentes históricos. É amplamente adotado em escala global como um roteiro prático e focado para a mitigação mensurável de riscos de segurança digital.

Em complemento, o CIS RAM (*Center for Internet Security Risk Assessment Method*), desenvolvido em parceria com a HALOCK Security Labs, constitui uma metodologia de avaliação de riscos ágil e estruturada. Seu propósito é viabilizar que as instituições apliquem os Controles CIS de acordo com suas realidades de negócio e necessidades específicas de segurança.

Graças a essa flexibilidade de aplicação, a modelagem se ajusta a organizações de variados portes e setores, propiciando que as medidas defensivas correspondam precisamente aos limites de risco tolerados por cada entidade.

O método CIS RAM orienta as organizações na busca por respostas a questões como: